AF2.3 · Department tab scoping, one department per intern

Agent Factory · Task AF2.3 · P0 · rollout blocker · measured 15 October 2026 · prepared for Ali Muwwakkil

ASKED Each intern sees and controls the admin surface for their own department, and no other.

DELIVERED The measurement, the domain-to-section mapping and the gap list — plus the finding that the per-intern section grants the ticket asks for cannot be issued without an RBAC change that is Ali's to approve. One live defect found while measuring, and fixed.

> **TAKEAWAY**
>
> **Only 2 of the 7 interns can be given their own department tab today without also being given most of the platform.**

1. **Sarbjit's marketing tab — the example used on the call — has no narrow role that reaches it.** The only roles including `campaigns` are Admin (13 of 14 sections) and Owner. It is also the richest surface of the ten, at 11 route prefixes. The same is true of Quincy's `platform`, which maps to `system`: tickets, reports, **settings**, events and automation.
2. **The ticket's named artifact cannot be produced as specified.** It asks for "a per-intern section grant". One role per person. Each role carries a FIXED set of sections. There is no per-person section grant. Issuing the grants needs four new roles and a widened CHECK constraint, which is an RBAC change and therefore yours.
3. **Two interns would share one role.** `admissions` grants `lead_ingestion` AND `internship`, so Kalkidan would also get Tashima's domain and Tashima would also get Kalkidan's. The internship queue carries an applicant's resume, phone number and interview transcript, which the code itself calls out as "a materially wider grant than editing curriculum".
4. **One intern's domain has no surface at all.** Nothing maps to `product_experience`, so there is nothing to grant Mihret and nothing to scope. No page was invented to close this, per the ticket's out-of-scope rule.
5. **Update rights are not the problem.** The gate never reads req.method, so a section grant covers GET and POST/PUT/DELETE alike. Link 2 needs UPDATE, and a section grant satisfies it. The one exception is `learner_success`, where `support` reaches only the read-only `students` surface and so fails link 2 anyway.

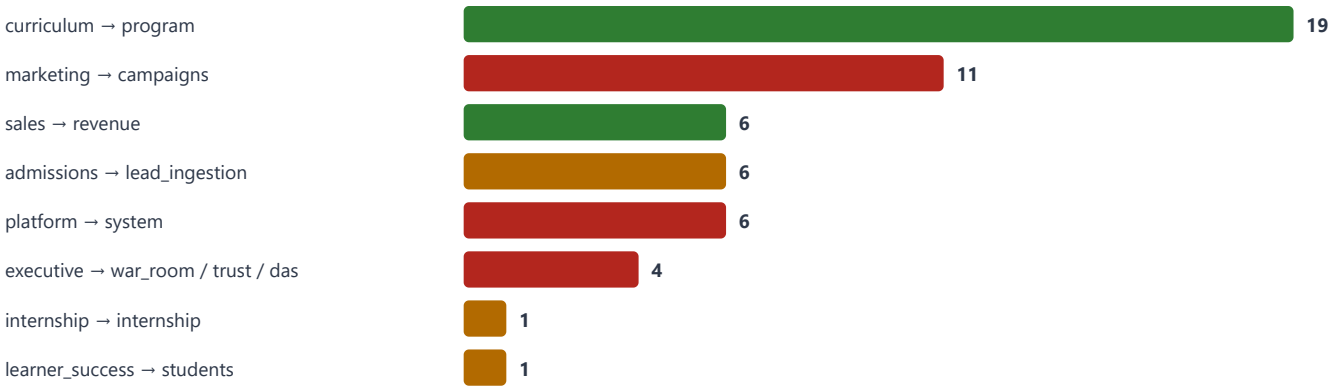
The mapping, measured

Read out of the gate's own path-to-section table and the role definitions, not from the nav. A nav entry is not access control, and this table is what the server enforces.

DOMAIN	INTERN	ADMIN SECTION	ROUTE PREFIXES	NARROWEST ROLE THAT REACHES IT	VERDICT
`curriculum`	Ruth Kumera	`program`	19	`curriculum` · dashboard + program	Scopable today
`sales`	Victoria Spencer-	`revenue`	6	`revenue` · dashboard +	Scopable today

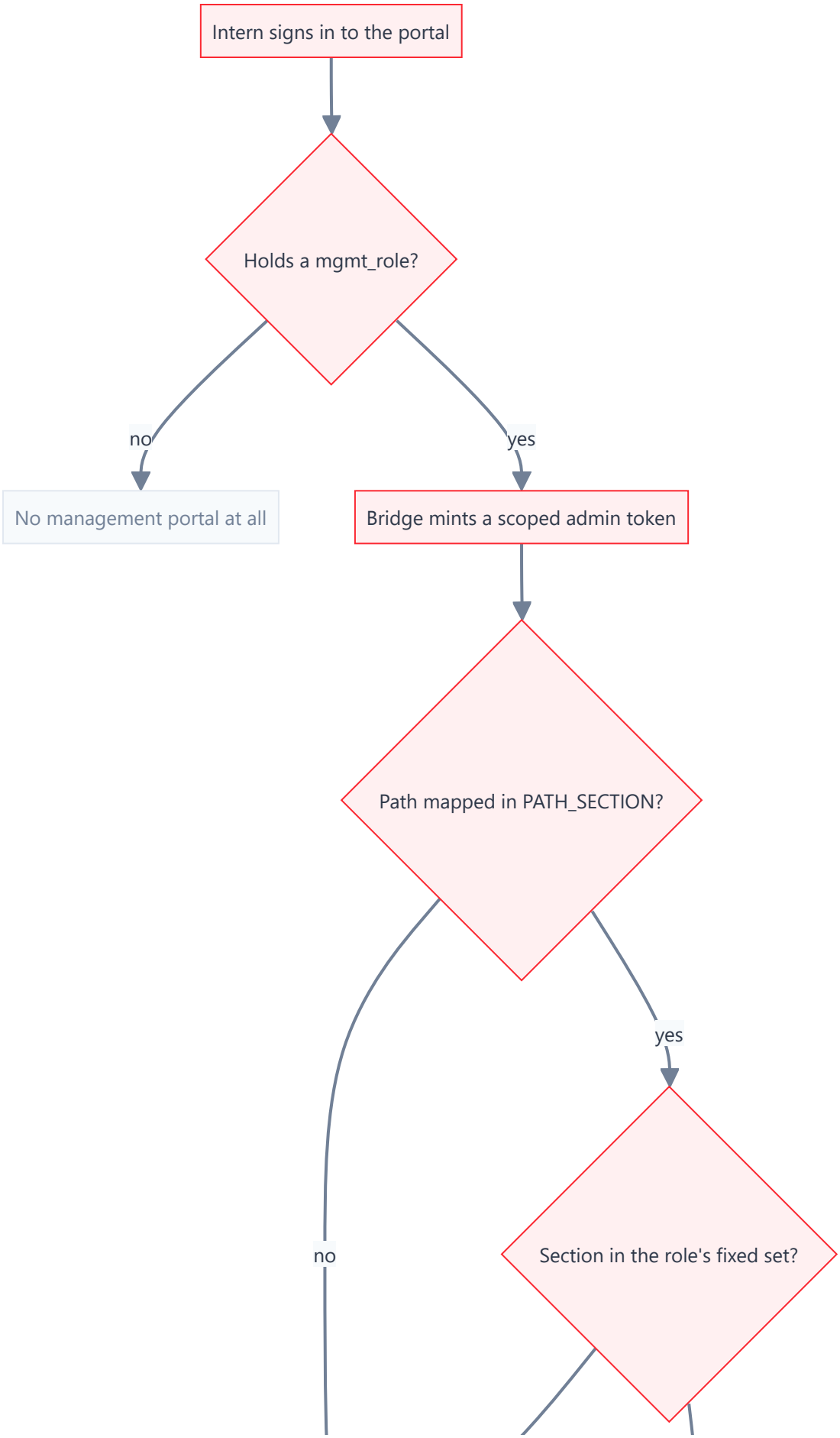
	Auber			revenue + leads	
`admissions`	Kalkidan Bezabeh	`lead_ingestion`	6	`admissions` · dashboard + lead_ingestion + internship	**Role covers two domains**
`internship`	Tashima Diah	`internship`	1	`admissions` · dashboard + lead_ingestion + internship	**Role covers two domains**
`marketing`	Sarbjit Kaur	`campaigns`	11	Admin (13 of 14) or Owner only	**No role below Admin**
`platform`	Quincy Nkwain Ninying	`system`	6	Admin (13 of 14) or Owner only	**No role below Admin**
`product_experience`	Mihret Netsereab	*none exists*	—	—	**No surface exists**
`executive`	*no intern assigned*	`war_room / trust / dashboard`	4	Admin (13 of 14) or Owner only	**No role below Admin**
`learner_success`	*no intern assigned*	`students`	1	`support` · students only	**Read-only surface**
`website`	*no intern assigned*	*none exists*	—	—	**No surface exists**

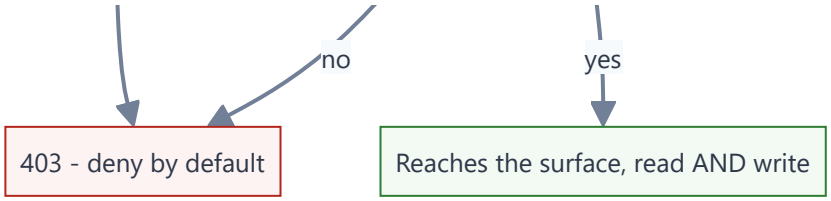
How much surface each grant actually carries



Admin path prefixes mapping to each domain's section, from the gate's own table. Bar colour is the scoping verdict. The two domains with no section are absent because they have nothing to count — `product_experience` and `website`.

Why a per-intern grant cannot be expressed


Intern signs in to the portal
Holds a mgmt_role?
no
yes
No management portal at all
Bridge mints a scoped admin token
Path mapped in PATH_SECTION?
yes
no
Section in the role's fixed set?



The grant path. The role is the only place a section can come from, which is why a per-intern grant cannot be expressed today. Note the absence of any method test: the gate never reads `req.method`, so reaching a section carries write as well as read.

Two facts a reader will otherwise assume wrongly.

Legacy admins bypass the gate entirely. if (!payload.mgmt_role) return next() — only bridge-minted staff tokens are gated, so a legacy admin login is scoped by nothing at all. This is why Taiwo passes all nine admissions routes today (AF2.6), and it means an intern given a legacy admin login would be scoped by nothing.

An unmapped path 403s its own owner. A scoped role is deny-by-default on an unmapped path, so a new surface that is not added to PATH_SECTION 403s its own owner.

A live defect found while measuring, and fixed

A role declared in TypeScript and rejected by Postgres. `mgmtRoles.ts` declared **8** management roles. The CHECK constraint permitted **7**. `mentor` was added to the type union and to the role definitions — deliberately, with a careful comment about per-mentor scoping — and the constraint was never widened, so `mgmt_role = 'mentor'` was **rejected by Postgres** and the role could not be assigned to anybody.



Storable and declared Declared but rejected by Postgres

> **latent, not live-broken.** Nobody held the role, so nothing visibly failed. The portfolio review queue simply had no mentors and nothing anywhere said why. Measured: 0 rows in `career_mentor_scopes`, 0 members holding the role.

The fix is one word; the test is the point. One word added to the CHECK constraint, plus a five-assertion parity test that reads the role list out of the shipped DDL and compares it to MGMT_ROLES in both directions. Reverting the one-word fix fails 3 of the 5 tests, naming `mentor` specifically.

> **Why this matters for your decision.** It is the proof that "just add a narrow role" is a schema change, and that the last time someone added a role they forgot the constraint. The DDL runs in a loop that swallows every failure into a console.warn, so a rejected ALTER is invisible on deploy.

The gap list the ticket asked for

Domains with no admin surface today (2 of 10): `product_experience`, `website`. No path prefix maps to either. No pages were invented.

Domains with a real surface but no narrow role (3 of 10): `marketing`, `platform`, `executive`.

Your decision

A Add four narrow roles ★ recommended

marketing, platform, executive, and split admissions from internship. Widens the CHECK constraint. Every new role is a strict subset of Admin.

Covers: All 7 interns scoped properly. · **Cost:** An RBAC and schema change, which is why it is yours to approve.

B Give the five uncovered interns Admin

Fast. It is 13 of 14 sections each.

Covers: All 7 interns reach their tab on Monday. · **Cost:** This ticket's own text names it as the trap: granting a broad role because it is quicker, then describing it as scoped.

C Ship Monday on what exists

Ruth and Victoria on real department tabs, the other five on the read-only My Domain page from AF2.1. Land the roles after.

Covers: 2 of 7 fully; 5 of 7 can see but not change. · **Cost:** Nothing false ships, and five interns cannot do link 2 on Monday.

D **Per-person section grants**

A new grant table; roles become defaults. The most correct long-term shape.

Covers: Everything, eventually. · **Cost:** The largest change here. Not a Monday option.

Separately, and smaller: Mihret's domain has no surface. Placeholder, or reassign her to a domain that has one?

What this does not establish

- **No grant has been issued to any intern.** Nobody's access changed. Ruth Kumera's onboarding requirements stand and she is not activated.
- **No role definition was widened.** Provable by `git diff` of `mgmtRoles.ts`, which is empty — AF2.3's fourth acceptance criterion.
- **The per-route live-call assertion is not done.** The ticket asks for each intern's token to be proven against its own surface and refused at least two others. That needs the grants to exist first, so it is blocked behind your decision rather than skipped. A role definition is not proof that a route is guarded.
- **One stale row, noted not touched.** `agent_domain_projects` still carries the old admissions blocker claiming Taiwo has no admin login. AF2.6 disproved it and PR #3100 corrected the registry, but the reconcile that rewrites those rows has not run on a deploy carrying the correction. A deploy-ordering issue, not a code one.

Sources: backend/src/middlewares/mgmtSectionGate.ts (PATH_SECTION) · backend/src/services/access/mgmtRoles.ts (MGMT_ROLE_DEFS) · accelerator_prod — community_members, agent_domain_projects, career_mentor_scopes. Built from the same data module as the one-page visual.